

CYBERSECURITY PORTFOLIO

GRC / ACCESS CONTROL EXERCISE

Hyper-V Least-Privilege Access Design

Carter Yanosick

Portfolio Edition

SANITIZED COPY

Original technical content and evidence preserved.
Other participant names removed for public portfolio use.

Week 3, Day 4

Who gets the keys?

PNC Cohort

8/20/2026

Role Matrix:

Role Name	Can Do	Explicitly Cannot Do	Applies To	Who Gets It
Hyper-V Engineer	Patch the host; configure virtual switches and storage	Routine Domain Admin use; access application/database data unless required; unrestricted actions outside approved administration	Hyper-V host	Marcus
App Support Restart Operator	Restart web-tier and app-tier during approved releases	Delete VMs, create checkpoints, change VM hardware/networking, restart db-tier, administer host	web-tier, app-tier	Priya
DBA Guest Administrator	Administer the database from inside db-tier	Hyper-V administration, VM deletion, VM configuration, direct checkpoint/restore rights	Inside db-tier only	Tom
Backup Operator	Run/monitor approved backups through the backup system	Interactive Hyper-V administration, delete VMs, modify networks/storage, use general administrator rights	web-tier, app-tier, db-tier backups	Dana
NOC Read-Only	View whether VMs are running and view basic health/status	Start, stop, restart, checkpoint, delete, or modify VMs	All three VMs	Kevin

Security groups as follows:

- Marcus = MTB-HV-Engineers
- Priya = MTB-HV-AppSupport-Restart
- Tom = MTB-HV-Administrators
- Dana = MTB-HV-Operators
- Kevin = MTB-HV-NOC-ReadOnly

How to Enforce It:

We would enforce the design using Windows security groups combined with PowerShell Just Enough Administration (JEA). Hyper-V's built-in Hyper-V Administrators group provides broad administrative access and does not provide the per-VM granularity required for Priya and Kevin. JEA would expose only approved Hyper-V PowerShell commands and restrict them to the VMs required by each role. Database administration and backup permissions would be handled inside their respective systems rather than by granting general Hyper-V administrator access.

For permissions Hyper-V cannot enforce precisely:

- Use PowerShell/JEA (Just Enough Administration) to expose only approved commands.
- Use Windows security groups to control who can access those constrained functions.
- Keep users out of the local Administrators group unless their job genuinely requires it.
- For backup software, use the vendor's documented least-privilege/service-account configuration rather than accepting generic administrator access.

One Risk You Can't Fix

All three critical banking systems are hosted on a single Hyper-V server, creating a single point of failure and a large security blast radius. RBAC can limit what individual users can do, but it cannot prevent a hardware failure or full hypervisor compromise from affecting the web, application, and database tiers at the same time.

Debrief Questions

1. Should Tom get checkpoint rights on `db-tier`? What is a checkpoint of that VM, exactly?
Tom should not get unrestricted checkpoint rights just because he wants them. A checkpoint is a saved point-in-time state of the VM that can include its virtual disks, configuration, and depending on checkpoint type, system state. Since db-tier contains customer and card data, that checkpoint is also sensitive and restoring it could roll the database back to an earlier state.
2. Marcus holds Domain Admin *and* hypervisor admin. What happens if he gets phished?
Marcus is a major security risk because he has both Domain Admin and Hyper-V admin privileges. If he gets phished, an attacker could potentially take control of the Hyper-V host, affect all the VMs, and potentially compromise the domain.
3. Dana's vendor asked for admin. What does backup software actually need?
Dana should not automatically get administrator rights. Backup software normally needs specific permissions to read/access the VMs, their virtual disks, or backup infrastructure. The vendor should provide its required permissions so the bank can give the backup account only what it actually needs.

4. Priya only reboots things. `app-tier` holds the wire transfer queue. Is that low-privilege?

It is low-privilege in terms of permissions, but high-impact in terms of risk. Priya can only reboot the VMs, but rebooting the app-tier could interrupt the wire transfer queue. This shows that least privilege considers both what someone can do and what that action can affect.